

Cirque Corporation

Monitoring, Measurement, Analysis, and Evaluation Policy

Document ID: IS-CIRQ-P-021-G

Category: ISMS Support Process

Division: Policy

Type: Global

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: Executive Committee

Generated: March 02, 2026

1. Purpose

The purpose of this policy is to define Cirque's framework for monitoring, measuring, analyzing, and evaluating the performance and effectiveness of its Information Security Management System (ISMS). This policy ensures that the ISMS is continually assessed against its objectives, controls are performing as intended, and opportunities for improvement are identified to maintain and enhance information security posture. This policy aligns with ISO/IEC 27001:2022 Clause 9.1 (Monitoring, measurement, analysis and evaluation).

****2. Scope****

2. Scope

This policy applies to all aspects of Cirque's ISMS, covering all processes, controls, and objectives defined within the ISMS scope, across all global operations (US, Taipei, China). It applies to all personnel involved in the monitoring, measurement, analysis, and

evaluation activities.

****3. Definitions****

3. Definitions

- ****Monitoring:**** Observing the status of the ISMS, a process, or a control to identify changes or deviations.
- ****Measurement:**** Quantifying the performance or effectiveness of a process or control.
- ****Analysis:**** Examination of data and information to identify trends, patterns, and root causes.
- ****Evaluation:**** Determining the significance, effectiveness, and suitability of the ISMS based on the results of monitoring, measurement, and analysis.
- ****ISMS Objectives:**** Specific, measurable, achievable, relevant, and time-bound goals for information security.
- ****Key Performance Indicators (KPIs):**** Measurable values that demonstrate how effectively an organization is achieving key business objectives.
- ****Key Risk Indicators (KRIs):**** Metrics used to provide an early signal of increasing risk exposure.

****4. Policy Requirements****

4. Policy Requirements

****4.1. What to Monitor, Measure, Analyze, and Evaluate:**** a. The performance of the ISMS as a whole. b. The effectiveness of information security controls. c. The achievement of information security objectives. d. Processes and procedures related to information security.

e. Risk levels and the effectiveness of risk treatment plans. f. Incidents and their resolution. g. Compliance with legal, regulatory, and contractual requirements.

4.2. How to Monitor, Measure, Analyze, and Evaluate: a. **Monitoring & Measurement:** Establish and track relevant Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) for information security. Examples include: Number of security incidents Mean Time To Detect (MTTD) and Mean Time To Respond (MTTR) for incidents. Number of successful phishing simulations. Vulnerability scan results (number of critical/high vulnerabilities). Compliance rates (e.g., patch management, password complexity adherence). Backup success rates. Utilize automated tools (e.g., SIEM, RMM, vulnerability scanners, log management systems) for continuous monitoring and data collection. Conduct regular reviews of logs, alerts, and system reports. Perform internal audits and independent reviews of specific controls or processes. b. **Analysis & Evaluation:** Analyze collected data to identify trends, patterns, root causes of incidents or control failures, and areas of non-compliance. Compare actual performance against defined ISMS objectives, KPIs, and KRIs. Evaluate the effectiveness of implemented controls in reducing identified risks. Assess the overall suitability, adequacy, and effectiveness of the ISMS.

4.3. When to Monitor, Measure, Analyze, and Evaluate: a. Monitoring and measurement activities shall be conducted on an ongoing basis for critical controls and systems. b. Formal analysis and evaluation of collected data shall occur at planned intervals, typically monthly or quarterly by relevant teams, and consolidated for management review. c. Significant changes to the ISMS, IT infrastructure, or the threat landscape may trigger immediate monitoring and evaluation activities.

****4.4. Who Monitors, Measures, Analyzes, and Evaluates:**** a. ****IT Department:**** Primarily responsible for technical monitoring and measurement, including system logs, network traffic, security tool outputs, and incident data. b. ****Security Team:**** Responsible for analyzing security-related data, conducting vulnerability assessments, and evaluating the effectiveness of security controls. c. ****Internal Audit Function:**** Conducts independent assessments of ISMS processes and controls. d. ****Management Review Committee:**** Responsible for the overall evaluation of the ISMS performance and effectiveness during management review meetings.

****4.5. Documentation and Reporting:**** a. The results of monitoring, measurement, analysis, and evaluation activities shall be documented. b. Reports on ISMS performance shall be generated periodically and presented to relevant stakeholders, including the Management Review Committee. c. Findings, conclusions, and recommendations for improvement shall be clearly documented.

****5. Improvement****

5. Improvement

The output of monitoring, measurement, analysis, and evaluation activities shall feed directly into Cirque's continual improvement process, leading to corrective actions, updates to policies/procedures, and enhancement of information security controls. (Refer to IS-CIRQ-P-023-G: Nonconformity and Corrective Action Policy and IS-CIRQ-P-024-G: Continual Improvement Policy).

****6. Responsibilities****

6. Responsibilities

- ****Executive Committee:**** Ensures adequate resources are allocated for monitoring, measurement, analysis, and evaluation activities and

reviews overall ISMS performance.

- **IT Manager:** Oversees the implementation and operation of technical monitoring and measurement tools and processes.
- **Information Security Officer/Team:** Directs and performs analysis and evaluation of security metrics, ensures compliance with this policy.
- **Process Owners:** Responsible for monitoring and measuring the performance of controls within their respective areas.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-P-001-G: Information Security Policy
- IS-CIRQ-PR-015-G: Logging and Monitoring Procedure
- IS-CIRQ-PR-022-G: ISMS Performance Monitoring Procedure
- IS-CIRQ-PR-023-G: Internal Audit Procedure
- IS-CIRQ-P-022-G: Management Review Policy
- IS-CIRQ-P-023-G: Nonconformity and Corrective Action Policy
- IS-CIRQ-P-024-G: Continual Improvement Policy

****8. Policy Review****

8. Policy Review

This policy will be reviewed at least annually, or sooner if there are significant changes to Cirque's ISMS, organizational structure, or external requirements.